

SIZMA TESTİ RAPORU

DOM XSS in jQuery anchor href attribute sink using location.search source

PortSwigger Web Security Academy Laboratuvarı

Hazırlayan: Şuheda EMLEK

Rapor Türü	Web Uygulama Güvenliği / Sızma Testi Raporu
Zafiyet Sınıfı	DOM tabanlı XSS
Etkilenen Bileşen	Geri bildirim sayfasındaki Back bağlantısı
Teknik Nokta	jQuery ile href özniteliğine location.search verisinin yazılması
Durum	Doğrulandı / Laboratuvar çözüldü

İçindekiler

1. Yönetici Özeti
2. Testin Amacı ve Kapsamı
3. Zafiyetin Teknik Tanımı
4. Kullanılan Payload ve Çalışma Mantığı
5. Adım Adım İstismar Süreci
6. Kanıt Ekran Görüntüleri ve Açıklamaları
7. Etki Analizi
8. Risk Değerlendirmesi
9. Düzeltme ve Önlem Önerileri
10. Sonuç

1. Yönetici Özeti

Bu rapor, PortSwigger Web Security Academy üzerinde yer alan "DOM XSS in jQuery anchor href attribute sink using location.search source" başlıklı laboratuvara ilişkin güvenlik test bulgularını içermektedir. Yapılan incelemede, geri bildirim sayfasındaki Back bağlantısının href özniteliğinin jQuery kullanılarak location.search verisiyle güncellendiği ve bu işlemin güvenli biçimde sınırlandırılmadığı görülmüştür.

Bu davranış, saldırganın returnPath parametresini javascript: şeması ile değiştirmesine olanak tanımaktadır. Sonrasında kullanıcı Back bağlantısına tıkladığında saldırgan kontrollü JavaScript kodu çalıştırılabilmektedir. Test kapsamında returnPath değeri javascript:alert(document.cookie) olacak şekilde değiştirilmiş, bağlantının href değeri inceleme aracında doğrulanmış ve bağlantıya tıklanmasıyla alert penceresinde değer görüntülenmiştir.

2. Testin Amacı ve Kapsamı

Bu testin amacı, geri bildirim gönderme sayfasındaki dönüş bağlantısının istemci tarafında nasıl üretildiğini analiz etmek ve DOM tabanlı XSS zafiyetinin pratik olarak istismar edilemeyeceğini doğrulamaktır.

Kapsam Unsuru	Açıklama
Hedef Sayfa	Feedback / geri bildirim gönderme sayfası
Kaynak (Source)	location.search içindeki returnPath parametresi
Sink	jQuery ile a öğesinin href özniteliği
Doğrulama Kriteri	Back bağlantısına tıkladığında JavaScript çalışması
Beklenen Sonuç	document.cookie bilgisinin alert ile görüntülenmesi ve lab solved olması

3. Zafiyetin Teknik Tanımı

DOM tabanlı XSS, zararlı girdinin istemci tarafındaki JavaScript tarafından DOM'a yerleştirilmesi ile oluşur. Bu laboratuvarında jQuery seçici fonksiyonu kullanılarak sayfadaki Back bağlantısı bulunmakta ve href özniteliği URL üzerindeki location.search verisinden türetilen returnPath parametresi ile güncellenmektedir.

Eğer uygulama javascript: gibi tehlikeli URI şemalarını engellemezse saldırgan bu değeri zararlı bir JavaScript ifadesiyle değiştirebilir. Kullanıcı bağlantıya tıkladığında tarayıcı bu değeri normal bir URL olarak değil, çalıştırılabilir JavaScript olarak yorumlar. Böylece istemci tarafında XSS gerçekleşir.

4. Kullanılan Payload ve Çalışma Mantığı

Öğ	Açıklama
İlk test değeri	/eda04
Amaç	returnPath değerinin gerçekten href içine taşındığını doğrulamak
Nihai payload	javascript:alert(document.cookie)
Çalışma Mantığı	Back bağlantısına tıklandığında href içindeki JavaScript çalışır
Doğrulama	Alert penceresinde değer görünür ve laboratuvar çözülür

5. Adım Adım İstismar Süreci

Adım 1 – Hedef laboratuvar sayfasının doğrulanması

İlk olarak laboratuvar sayfası açılmış, başlığın jQuery anchor href attribute sink using location.search source olduğu doğrulanmış ve sağ üst bölümde durum bilgisinin Not solved olduğu görülmüştür. Ardından Submit feedback bağlantısına geçilerek hedef form sayfası açılmıştır.

Adım 2 – returnPath parametresinin rastgele değer ile test edilmesi

Adres çubuğunda feedback sayfasının returnPath parametresi rastgele bir değerle değiştirilmiştir. Amaç, bu değerin sayfa içinde Back bağlantısının href özniteliğine taşınıp taşınmadığını tespit etmektir.

Adım 3 – İnceleme aracı ile sink doğrulaması

Sayfa üzerinde sağ tıklayıp İncele seçeneği kullanılmış ve DOM içinde Back bağlantısının href değerinin returnPath parametresi ile oluşturulduğu gözlemlenmiştir. Böylece sink noktasının a href özniteliği olduğu doğrulanmıştır.

Adım 4 – Zararlı payload'ın yerleştirilmesi

returnPath değeri javascript:alert(document.cookie) olarak değiştirilmiştir. Bu değişiklik sonrası inceleme ekranında href özniteliğinin javascript protokolünü içerdiği görülmüştür.

Adım 5 – Bağlantıya tıklanması ve XSS doğrulaması

Back bağlantısına tıkladığında tarayıcı javascript URI değerini çalıştırmış, alert penceresi açılmış ve laboratuvar solved durumuna geçmiştir. Böylece DOM XSS zafiyeti uygulamalı olarak doğrulanmıştır.

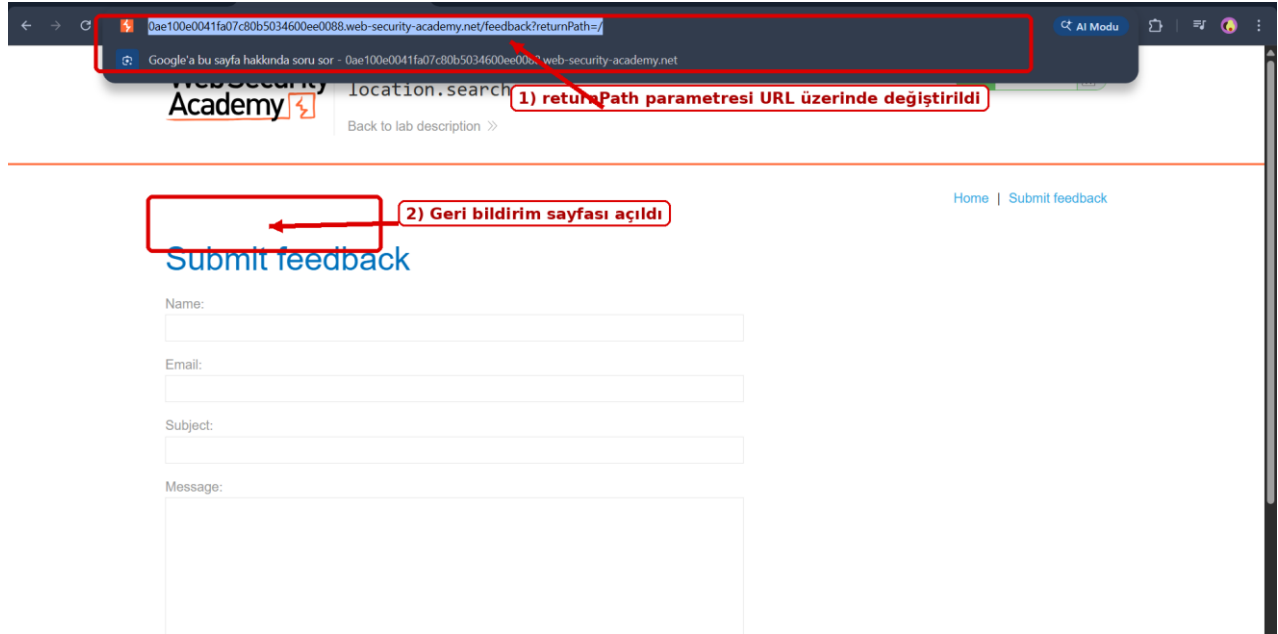
6. Kanıt Ekran Görüntüleri ve Açıklamaları

Şekil 1 – Başlangıç laboratuvar ekranı



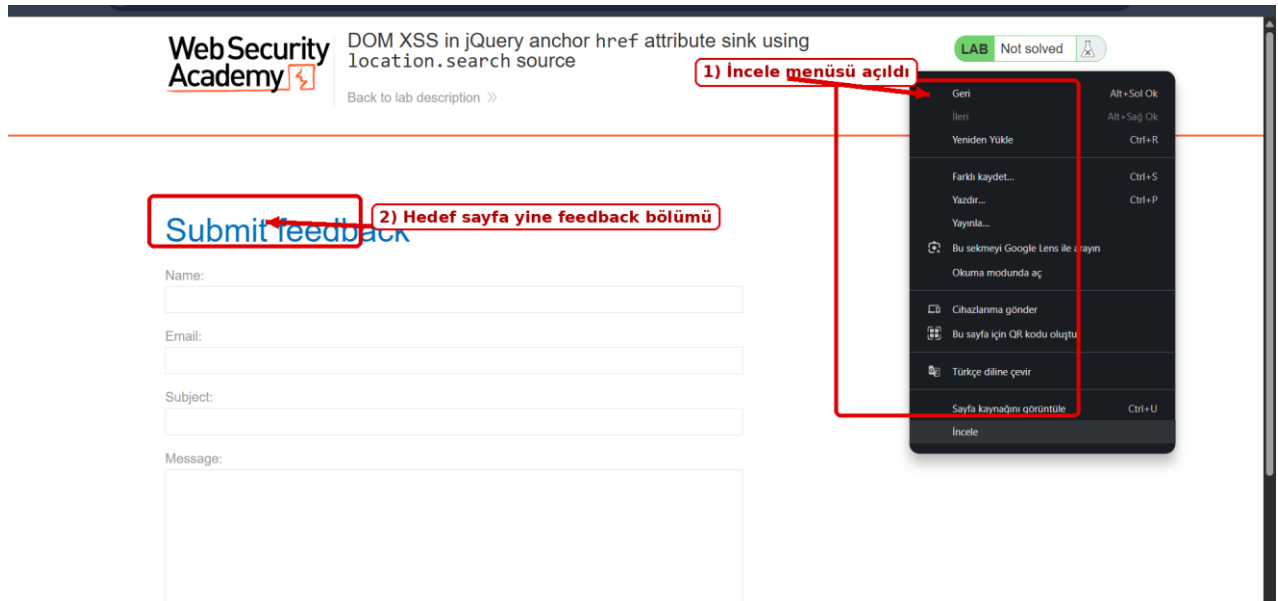
Açıklama: Kırmızı işaretlemeler ile laboratuvar başlığı, başlangıç durumu ve Submit feedback bağlantısı gösterilmiştir. Bu ekran testin doğru hedef sayfada başlatıldığını kanıtlamaktadır.

Şekil 2 – Feedback sayfasına geçiş ve returnUrl parametresinin değiştirilmesi



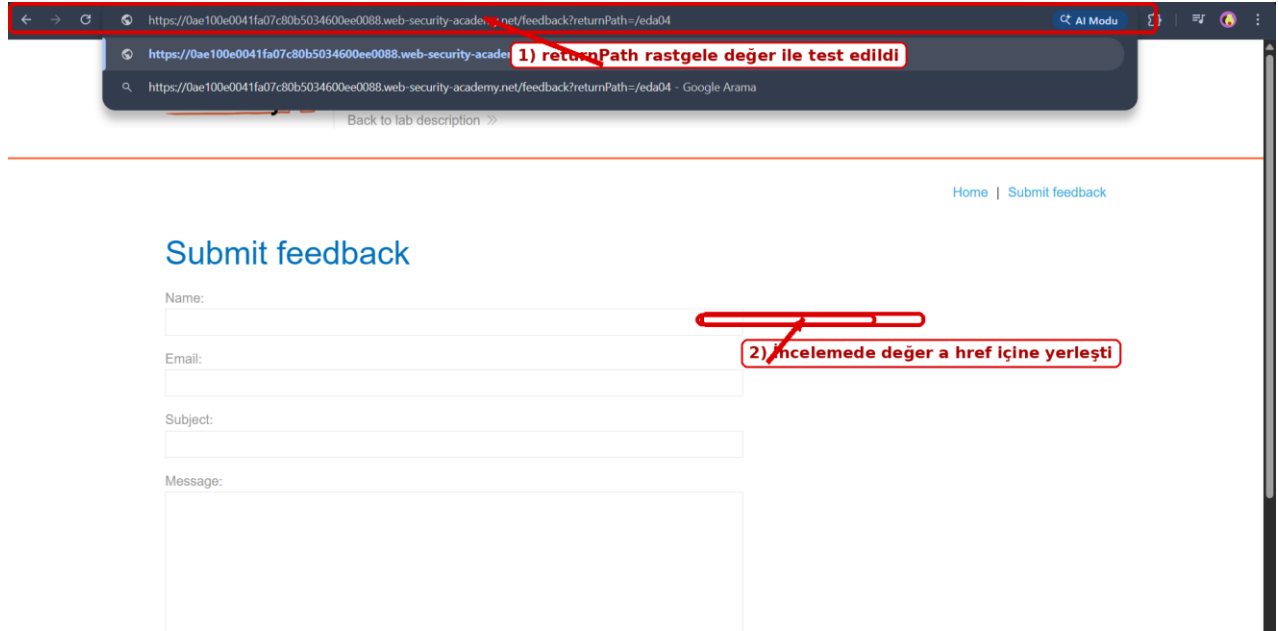
Açıklama: Adres çubuğunda feedback sayfası açılmış ve returnUrl değeri rastgele bir yol ile test amaçlı değiştirilmiştir.

Şekil 3 – İncele adımının başlatılması



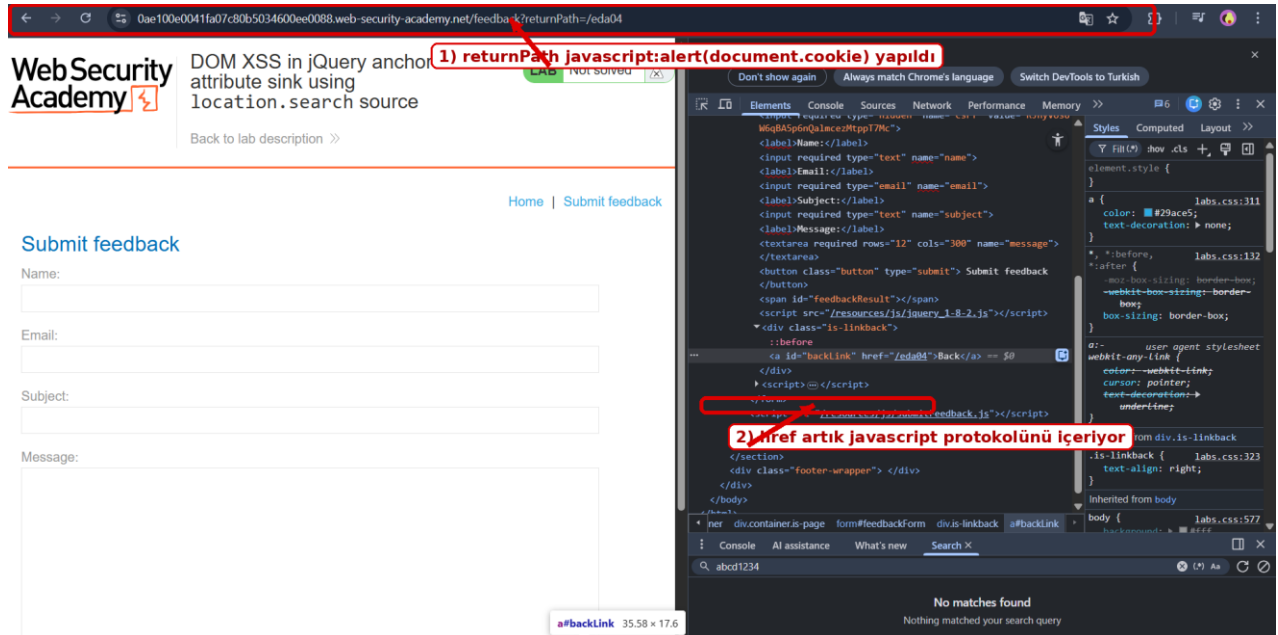
Açıklama: Sağ tıklama menüsü açılarak inceleme aracına geçiş hazırlanmıştır. Bu adım sink noktasını doğrulamak için gerçekleştirilmiştir.

Şekil 4 – Rastgele değerin Back bağlantısının href özneliğine yerleştiğinin doğrulanması



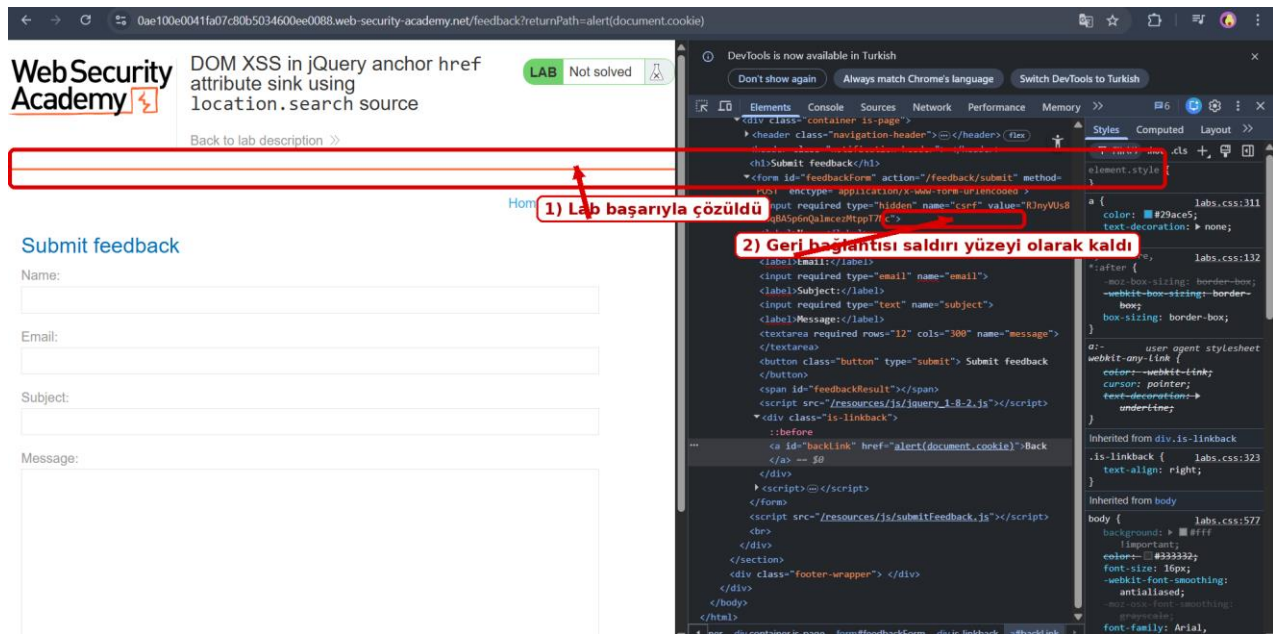
Açıklama: Geliştirici araçlarında a id='backLink' öğesinin href değerinin test amaçlı girilen returnPath değeri ile oluşturulduğu görülmektedir.

Şekil 5 – Zararlı payload'ın href içine yerleşmesi



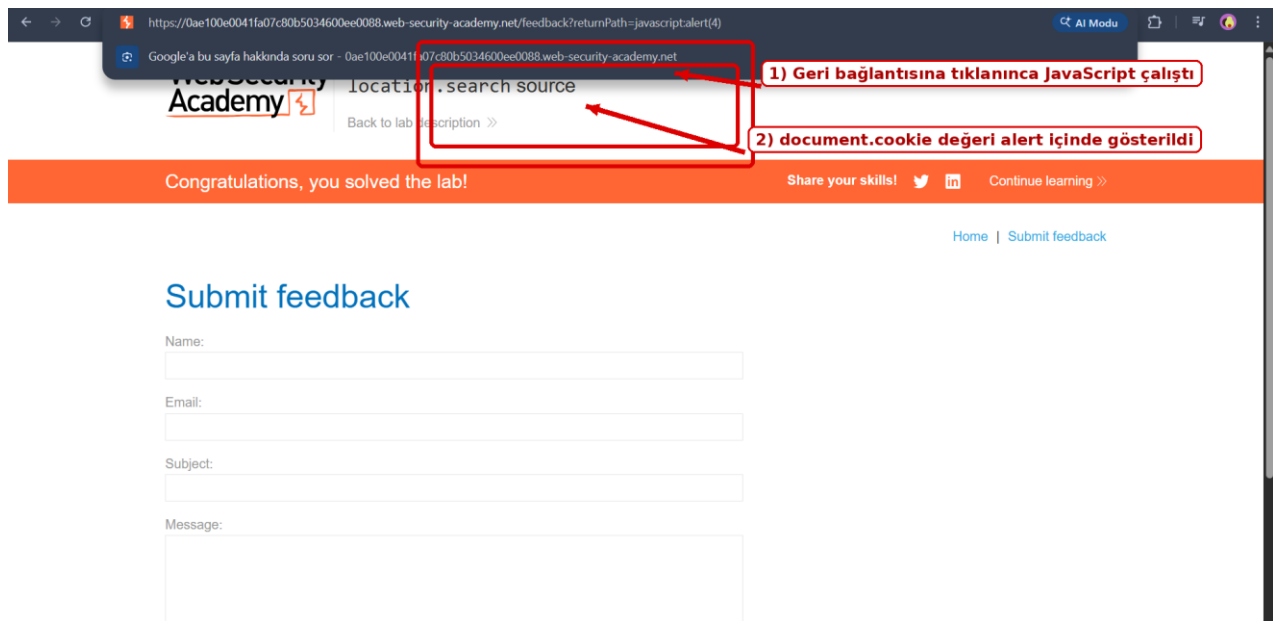
Açıklama: returnPath parametresi javascript:alert(document.cookie) yapıldıktan sonra, aynı değer DOM içinde Back bağlantısının href özneliğinde doğrulanmıştır.

Şekil 6 – Laboratuvarın çözülmesi



Açıklama: Başarı bandı ekranın üst kısmında görüntülenmiş ve laboratuvarın çözüldüğü doğrulanmıştır.

Şekil 7 – Back bağlantısına tıklanınca JavaScript kodunun çalışması



Açıklama: Alert penceresi açılmış, bağlantı tıklaması sonucunda JavaScript kodunun çalıştığı doğrulanmıştır.
Bu davranış zafiyetin doğrudan istismar edildiğini göstermektedir.

7. Etki Analizi

Gerçek bir uygulamada bu zafiyet, saldırganın kullanıcıyı hazırlanmış bir feedback bağlantısına yönlendirmesiyle istismar edilebilir. Kullanıcı Back bağlantısına güvendiği için, bağlantı tıklamasıyla birlikte saldırgan kontrollü kod çalışabilir.

- Kurban kullanıcının tarayıcısında keyfi JavaScript çalıştırılması
- Çerez veya istemci tarafı verilerinin ele geçirilmesi
- Kullanıcının zararlı bir sayfaya yönlendirilmesi
- Form, görünüm veya içerik manipülasyonu ile kimlik avı senaryoları oluşturulması

8. Risk Değerlendirmesi

Kriter	Değerlendirme
Zafiyet Türü	DOM XSS
Sömürülebilirlik	Yüksek
Teknik Karmaşıklık	Düşük
Kullanıcı Etkisi	Yüksek
Genel Risk Seviyesi	Yüksek

9. Düzeltme ve Önlem Önerileri

- location.search içinden gelen returnPath değeri doğrudan href özniteliğine yazılmamalıdır.
- Yalnızca güvenli ve beklenen yol değerleri kabul edilmeli, javascript: gibi protokoller engellenmelidir.
- URI doğrulaması yapılmalı ve yalnızca görelî yol veya güvenilir alan adları whitelist mantığı ile izinlenmelidir.
- jQuery veya benzeri kütüphanelerle DOM güncellenirken güvenilmeyen kaynaklar için güvenli dönüştürme uygulanmalıdır.
- İçerik Güvenlik Politikası (CSP) ve güvenli bağlantı işleme kuralları ile istemci tarafı risk azaltılmalıdır.

10. Sonuç

Gerçekleştirilen test sonucunda geri bildirim sayfasındaki Back bağlantısının href özniteliği üzerinden DOM tabanlı XSS zafiyeti bulunduğu doğrulanmıştır. returnPath parametresinin jQuery ile güvenli kontroller olmadan bağlantıya aktarılması, saldırganın javascript: şeması kullanarak istemci tarafında kod çalıştırmasına imkan vermektedir. Ekran görüntüleri ve adım adım süreç, zafiyetin başarıyla istismar edildiğini açık biçimde ortaya koymaktadır.